

nTZS — Key Management & Access Controls

Prepared for: Bank of Tanzania — Pre-Testing On-Site Inspection **Sandbox Ref:** LD.170/515/02/1254 · **Prepared:** 8 July 2026
Owner: Victor Muhagachi, CTO — victor@nedapay.xyz

1. Smart-contract authority

- **Contract:** nTZS (NTZSV2), `0xF476BA983DE2F1AD532380630e2CF1D1b8b10688` — UUPS-upgradeable ERC-20 on Base Mainnet (chain ID 8453), independently verifiable on BaseScan.
- **On-chain roles:** | Role | Purpose | |---|---| | `MINTER_ROLE` | Issue nTZS after confirmed cash | | `BURNER_ROLE` | Burn nTZS on redemption | | `BLACKLISTER_ROLE` | Freeze a wallet for AML/compliance | | Upgrade/admin | Authorise UUPS upgrades |
- **Authority holder:** a **Gnosis Safe multisig** — `0xB2b8C08a9AEB0E22242e6fC9cD78FC2402cBC503` — holds the privileged roles. Upgrades and role changes execute only through the Safe.

Current state & planned hardening (disclosed proactively)

- The mint and burn operations are currently executed by the **same Safe-controlled key**; there is **no separation** between mint and burn authority yet.
- **Planned before scale:** provision a **dedicated burner key** distinct from the minter, and increase multisig signer count / threshold. Smart-contract minting and redemption undergo **independent third-party audit before go-live and after any material code change** (Cantina audit on file, commit `e7ac3ac4`).

2. Off-chain secrets & platform access

- **Secret storage:** operational secrets (RPC, signer keys, PSP keys, DB credentials, webhook secrets) are held as encrypted environment variables in the hosting platform (Vercel); no secrets in source control.
- **Application access control:** role-based access (RBAC) — `end_user` , `platform_compliance` , `super_admin` , and a read-only `bot_regulator` role for the Oversight portal.
- **Dual control (maker-checker):** privileged money actions — mints, burns/redemptions, FX-rate changes, and treasury withdrawals — require an **operator to initiate and a separate approver to authorise**. An operator cannot approve their own request.
- **Webhook integrity:** all PSP webhooks are **HMAC-verified and fail closed** on a missing secret, bad signature, or stale timestamp.
- **Idempotency:** money-moving endpoints are idempotency-keyed to prevent duplicate mints/payouts on retries or replays.

3. Key lifecycle

- **Generation & custody:** privileged authority via the Safe multisig; signer keys held by named officers.
- **Rotation:** platform secrets rotated on personnel change or suspected exposure; Safe signers changed only through a Safe transaction.
- **Revocation:** a compromised signer is removed from the Safe; a compromised platform secret is rotated immediately and the incident-response plan is invoked.
- **Kill-switch:** minting and swaps can be paused on direction (including BoT direction); redemptions remain available so holders can always exit.

4. Audit & monitoring

- Every mint, burn, and role/upgrade action is **on-chain and timestamped**.
- Administrative actions are recorded in an internal audit log surfaced (in plain language) in the Oversight portal.
- The Safe multisig and contract roles are monitored; unexpected privileged activity is a SEV-1 incident.